

Cybersecurity Daily Newsletter

Vol. 002 | 2026-06-15 07:00 WIB

Top 5 Highlights

- CVE-2026-54411 | Linux-PAM up to 1.7.2 pam_userdb.c strcmp timing discrepancy (EUVD-2026-36662)
- CVE-2026-54413 | driftregion iso14229 up to 0.9.0 iso14229.c Handle_0x27_SecurityAccess integer underflow (EUVD-2026-36664)
- CVE-2026-54410 | debevv nanoMODBUS up to 1.23.0 MBAP recv_msg_header off-by-one (EUVD-2026-36661)
- CVE-2026-54412 | LiamBindle MQTT-C up to 1.1.6 PUBLISH src/mqtt.c mqtt_unpack_publish_response out-of-bounds (EUVD-2026-36663)
- FBI disrupts massive AI-powered phishing service using a million URLs

Threat Intelligence (10)

01. FBI disrupts massive AI-powered phishing service using a million URLs

In a coordinated effort, the FBI, working with Google and Black Lotus Labs, has dismantled a massive Chinese phishing-as-a-service operation called Outsider Enterprise with thousands of phishing websites used to steal credit card data and passwords. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.bleepingcomputer.com/news/security/fbi-disrupts-massive-ai-powered-phishing-service-using-a-million-urls/>

02. [+24h Old] NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks

By default, npm install will no longer execute scripts from dependencies, unless explicitly allowed. The post NPM 12 Will Change Script Execution Behavior to Prevent Supply Chain Attacks appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.securityweek.com/npm-12-will-change-script-execution-behavior-to-prevent-supply-chain-attacks/>

03. [+48h Old] China-nexus group hid in Linux login system for nearly a decade

The group's operation, dubbed Operation Highland, involved backdooring the Pluggable Authentication Modules (PAM) and OpenSSH components, which are fundamental to user authentication on Linux systems.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/china-nexus-group-hid-in-linux-login-system-for-nearly-a-decade>

04. [+48h Old] Over 400 Arch Linux AUR Packages Hijacked to Deploy Infostealer and eBPF Rootkit

Attackers took over more than 400 packages in the Arch User Repository (AUR) this week and rewrote their build scripts to install a credential stealer on any machine that built them. The malware is a Rust binary built to harvest developer secrets. When it lands with root, it can also load an eBPF rootkit to hide itself. The AUR is Arch Linux's community pac...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/over-400-arch-linux-aur-packages.html>

05. [+48h Old] China-Linked Hackers Backdoored Linux Login Software to Hide for Nearly a Decade

Instead of hiding on the laptops and servers defenders watch most closely, a China-nexus group spent close to a decade hidden inside the Linux login system itself. Sygnia, which tracks the group as Velvet Ant, says it backdoored the PAM and OpenSSH components that decide who is allowed to sign in, planting its access where ordinary cleanup could not reach i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/06/china-linked-hackers-backdoored-linux.html>

06. [+48h Old] Over 400 Arch Linux packages compromised to push rootkit, infostealer

More than 400 packages in the Arch User Repository (AUR) are distributing a Linux rootkit and infostealer malware targeting credentials and access tokens. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/over-400-arch-linux-packages-compromised-to-push-rootkit-infostealer/>

07. [+48h Old] Warrantless wiretaps cut off for a week following US Congress vote

Lawmakers have failed to extend a surveillance law that allows US intelligence agencies to monitor targets abroad without a warrant. Congress rejected a vote to extend Section 702 of the Foreign Intelligence Surveillance Act to July 2, which means, for a few days at least, some surveillance will be put on hold, for the first time since the Act was passed in...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.csoonline.com/article/4184603/warrantless-wiretaps-cut-off-for-a-week-following-u-s-congress-vote.html>

08. [+48h Old] The Good, the Bad and the Ugly in Cybersecurity - Week 24

Authorities seize crypto-laundering network and fake recruitment sites, JDY botnet targets U.S. military, and Miasma worm infects Microsoft and PyPi repos.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.sentinelone.com/blog/the-good-the-bad-and-the-ugly-in-cybersecurity-week-24-7/>

09. [+48h Old] GitHub to Update npm to Thwart Software Supply Chain Attacks

NPM, part of GitHub, announced a new version of the npm package manager with several security improvements, including disabling install scripts

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://www.infosecurity-magazine.com/news/github-update-npm-supply-chain/>

10. [+48h Old] ISC Stormcast For Friday, June 12th, 2026

<https://isc.sans.edu/podcastdetail/9970>, (Fri, Jun 12th)

ISC Stormcast For Friday, June 12th, 2026 <https://isc.sans.edu/podcastdetail/9970>, (Fri, Jun 12th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://isc.sans.edu/diary/rss/33074>

Latest Vulnerabilities (10)

01. CVE-2026-54411 | Linux-PAM up to 1.7.2 pam_userdb.c strncmp timing discrepancy (EUVD-2026-36662)

A vulnerability identified as problematic has been detected in Linux-PAM up to 1.7.2 . This issue affects the function strncmp of the file modules/pam_userdb/pam_userdb.c . Performing a manipulation results in observable timing discrepancy. This vulnerability is cataloged as CVE-2026-54411...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuln.db.com/vuln/370870>

02. CVE-2026-54413 | driftregion iso14229 up to 0.9.0 iso14229.c Handle_0x27_SecurityAccess integer underflow (EUVD-2026-36664)

A vulnerability categorized as critical has been discovered in driftregion iso14229 up to 0.9.0 . This vulnerability affects the function Handle_0x27_SecurityAccess of the file iso14229.c . Such manipulation leads to integer underflow. This vulnerability is listed as CVE-2026-54413 . The attack may be performed from remote. There is no available exploit.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370869>

03. CVE-2026-54410 | debevv nanoMODBUS up to 1.23.0 MBAP recv_msg_header off-by-one (EUVD-2026-36661)

A vulnerability was found in debevv nanoMODBUS up to 1.23.0 . It has been rated as critical . This affects the function recv_msg_header of the component MBAP Handler . This manipulation causes off-by-one. This vulnerability is tracked as CVE-2026-54410 . The attack is possible to be carried out remotely. No exploit exists.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370868>

04. CVE-2026-54412 | LiamBindle MQTT-C up to 1.1.6 PUBLISH src/mqtt.c mqtt_unpack_publish_response out-of-bounds (EUVD-2026-36663)

A vulnerability was found in LiamBindle MQTT-C up to 1.1.6 . It has been declared as problematic . Affected by this issue is the function mqtt_unpack_publish_response of the file src/mqtt.c of the component PUBLISH Handler . The manipulation results in out-of-bounds read. This vulnerability is identified as CVE-2026-54412...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370867>

05. CVE-2026-12223 | Yealink SIP-T46U 108.86.0.118 Web FastCGI Service tftpuploadiperf mod_webd.TFTPUploadIperf ip/port command injection

A vulnerability was found in Yealink SIP-T46U 108.86.0.118 . It has been classified as critical . Affected by this vulnerability is the function mod_webd.TFTPUploadIperf of the file /api/inner/tftpuploadiperf of the component Web FastCGI Service...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370866>

06. CVE-2026-12222 | Yealink SIP-T46U 108.86.0.118 Web FastCGI Service /api/inner/bttest mod_webd.BlueToothTest btMac/pin/reserved stack-based overflow

A vulnerability was found in Yealink SIP-T46U 108.86.0.118 and classified as critical . Affected is the function mod_webd.BlueToothTest of the file /api/inner/bttest of the component Web FastCGI Service...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370865>

07. CVE-2026-12221 | Yealink SIP-T46U 108.86.0.118 Firmware Chunk Upload /api/upgrade/upgrade sprintf uid/start_offset stack-based overflow

A vulnerability has been found in Yealink SIP-T46U 108.86.0.118 and classified as critical . This impacts the function sprintf of the file /api/upgrade/upgrade of the component Firmware Chunk Upload Handler . Performing a manipulation of the argument uid/start_offset results in stack-based buffer overflow. This vulnerability was named CVE-2026-12221...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370864>

08. CVE-2026-12220 | Yealink SIP-T46U 108.86.0.118 Firmware Chunk Upload handler accupgradebychunk mod_upgrade.SparePartsUpload uid stack-based overflow

A vulnerability, which was classified as critical , was found in Yealink SIP-T46U 108.86.0.118 . This affects the function mod_upgrade.SparePartsUpload of the file /api/upgrade/accupgradebychunk of the component Firmware Chunk Upload handler...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370863>

09. CVE-2026-12219 | Yealink SIP-T46U 108.86.0.118 Web FastCGI Service /api/diagnosis/start mod_diagnose.CommandShellByType Time command injection

A vulnerability, which was classified as critical , has been found in Yealink SIP-T46U 108.86.0.118 . The impacted element is the function mod_diagnose.CommandShellByType of the file /api/diagnosis/start of the component Web FastCGI Service . This manipulation of the argument Time causes command injection. This vulnerability is handled as CVE-2026-12219...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370862>

10. CVE-2026-12218 | Yealink SIP-T46U 108.87.50.1 Web FastCGI Service beforewifitest StartReportInformation port stack-based overflow

A vulnerability classified as critical was found in Yealink SIP-T46U 108.87.50.1 . The affected element is the function StartReportInformation of the file /api/inner/beforewifitest of the component Web FastCGI Service . The manipulation of the argument port results in stack-based buffer overflow. This vulnerability is known as CVE-2026-12218...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://vuldb.com/vuln/370861>

Data Breach & Cybercrime (10)

01. [+48h Old] Novo Nordisk discloses data breach affecting patient and healthcare professional information

Attackers gained access to Novo Nordisk's internal IT systems, copying non-public data without authorization.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/novo-nordisk-discloses-data-breach-affecting-patient-and-health-care-professional-information>

02. [+48h Old] Maine disables data breach notification portal after fake disclosures

Maine has taken its public data breach reporting portal offline after fraudulent breach disclosures were published on the state's website, prompting a review of procedures to

prevent abuse in the future. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/maine-disables-data-breach-notification-portals-after-fake-disclosures/>

03. [+48h Old] Google Sues Chinese Smishing Network Accused of Using Gemini AI in Phishing

Google on Friday said it's pursuing legal action against a Chinese cybercrime network, accusing it of using its Gemini artificial intelligence (AI) agent to send phishing text messages targeting Americans. The network is said to be behind the development and management of a phishing-as-a-service (PhaaS) software kit called Outsider, per the tech giant. "The...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/06/google-sues-chinese-smishing-network.html>

04. [+48h Old] Ukrainian national pleads guilty to role in Conti ransomware operation

A Ukrainian national extradited from Ireland to the United States last year has pleaded guilty to conspiracy charges tied to the Conti ransomware operation. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.bleepingcomputer.com/news/security/ukrainian-national-pleads-guilty-to-role-in-conti-ransomware-operation/>

05. [+48h Old] French government's secure messaging system breached

An intruder has breached the French government's encrypted messaging service, Tchap, showing once again that human error is a weak spot in any security system. Tchap was developed in France as an example of national sovereignty and was designed to be a more secure option than WhatsApp for communication between government employees. In this case, it wasn't t...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.csoonline.com/article/4184576/french-governments-secure-messaging-system-breached.html>

06. [+48h Old] Stolen iPhones could soon be worth a lot less to thieves

Apple and the Met Police are working together to make stolen iPhones harder to reset, resell, and profit from.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/mobile/2026/06/stolen-iphones-could-soon-be-worth-a-lot-less-to-thieves>

07. [+48h Old] Early Warning Signs of Supply-Chain Attacks Live in the Dark Web

GitHub access sales, leaked repositories, and stolen API keys can all become supply-chain attack footholds. Flare explores how underground forums expose early signals tied to software supply-chain risk. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/early-warning-signs-of-supply-chain-attacks-live-in-the-dark-web/>

08. [+48h Old] Ransomware Payment Crypto Laundering Platform Taken Out by FBI and Europol

Domain of dark web money laundering platform AudiA6 seized and suspects arrested in joint operation by the FBI, Europol and others

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://www.infosecurity-magazine.com/news/ransomware-crypto-laundering/>

09. [+48h Old] Novo Nordisk reports cyberattack as UK gives Wegovy pill the nod

Clinical trial participant data stolen, but pharma giant says exposed records were pseudonymized

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/security/2026/06/12/novo-nordisk-says-hackers-stole-clinical-trial-data/5254812>

10. [+48h Old] Google sues China-based scammers over Gemini AI abuse

Google has filed a lawsuit against Outsider Enterprise, a China-based cybercrime network for using AI tools, including Gemini, to build phishing websites and scam infrastructure. The company said the operation has affected “hundreds of thousands of victims,” with losses estimated in the millions of dollars. It also links the group to more than 9,000 fake we...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/06/12/google-china-based-cybercrime-network-lawsuit/>